FinSec 1.0: An Interactive Phishing Simulation and Just-in-Time Coaching System for FinTech Employee Awareness

Mohamed Ashraf, Abdulqudus Jimoh, Mubarak Jimoh, Ahmed Maher
Arab Academy of Science, Technology & Maritime Transport (AASTMT)
Smart Village, Giza, Egypt

***Abstract*—Human-factor weaknesses remain one of the most exploited entry points in FinTech environments, where attackers use urgency, authority, and deception to bypass technical controls through phishing and social engineering. Traditional awareness training (slides and videos) often fails to produce lasting behavior change because it is passive and rarely mirrors real decision pressure. This paper presents *FinSec 1.0*, a prototype phishing simulation and just-in-time coaching platform designed to improve employee decision-making through realistic drills, immediate feedback, and measurable outcomes. The system supports administrator-driven campaigns, template-based phishing scenarios, and a post-incident "AI Coach" quiz gate that unlocks acknowledgment and reinforces correct behavior. We report an experimental pilot in collaboration with a FinTech organization in Egypt (PAPS), where 15 participants completed baseline drills followed by post-training drills. Quantitative results (click/report behavior, risk scoring) and qualitative feedback indicate improved reporting behavior and increased caution when inspecting URLs and sender identity. The system demonstrates a practical, auditable training workflow suitable for FinTech organizations, with clear paths for scaling, automation, and compliance-oriented reporting.**

***Keywords*—Phishing Simulation, Security Awareness, Human Factors, Behavioral Training, FinTech Security, Just-in-Time Coaching**

I. Introduction

Traditional cybersecurity defenses alone are not sufficient to address human-factor errors, and when organizations overcorrect with strict controls they often reduce usability. This is especially visible in the rising scale and sophistication of phishing, driven by easy access to exploit kits and automation, enabling low-skill attackers to target employees at volume. Even skilled attackers still use phishing for reconnaissance and credential capture in environments where direct technical exploitation is difficult.

FinTech environments are particularly sensitive to phishing because successful compromise can directly lead to financial fraud, regulatory exposure, data leakage, and customer trust damage. Employees frequently operate under workload, urgency, and communication noise, which increases susceptibility to social engineering cues ("act now," "CEO request," "account verification," etc.). In practice, users do not fail because they are unintelligent; they fail because attackers intentionally exploit predictable cognitive shortcuts.

This highlights the demand for training methods that do more than transfer knowledge. Effective training must build *behavior*: repeated practice under realistic conditions, immediate feedback, and measurable outcomes. Based on the problems identified in traditional training and modern work environments, we emphasize five requirements:

1) **Interactivity** for attention retention and decision engagement.
2) **Realism** to mirror how phishing appears in real channels.
3) **Consistency** to reduce memory slips through repetition.
4) **Scoring** to quantify risk and improvement across drills.
5) **Safe enclosed environment** to practice without real harm.

This project proposes and implements *FinSec 1.0*, an administrator-operated platform that delivers phishing drills, triggers just-in-time coaching after risky actions, and records performance analytics. While an AI-driven bot approach was initially considered, the prototype was redesigned to be administrator-operated due to safety concerns, time constraints, and resource limitations. AI is retained as a future direction for controlled automation rather than unrestricted generation.

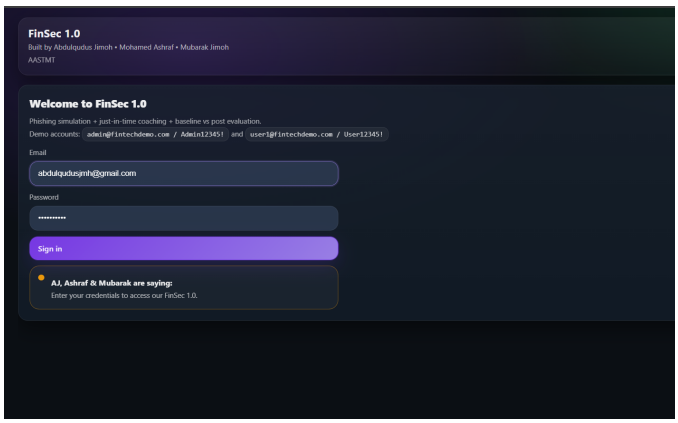

Fig. 1. FinSec 1.0 login interface showing system entry point and demo access credentials.

As shown in Fig. 1, FinSec 1.0 begins with a simple entry point for the administrator and employee roles. This separation supports controlled experiments and prevents employee-facing workflows from exposing administrative controls.

II. Related Work

Awareness training commonly relies on short videos, slides, and periodic quizzes. These formats improve familiarity with terms but often fail to change behavior when real phishing pressure occurs. Phishing simulations improve realism by presenting employees with crafted messages, yet many simulations stop at "clicked/not clicked" metrics without reinforcing learning immediately after risky actions.

Human-factor research highlights that susceptibility is linked to cognitive biases such as authority, urgency, and scarcity. Effective training should directly challenge these cues repeatedly in context, rather than expecting employees to apply lessons from passive content weeks later.

FinSec 1.0 follows a behavioral approach: the employee experiences a drill, takes an action, receives immediate consequence and coaching, and then must complete a short quiz gate to unlock acknowledgment. This creates a feedback loop between action and learning, increasing the chance of retention and safe behavior.

III. System Overview and Architecture

FinSec 1.0 is designed around two primary actors:

- **Administrator (Security/Training Lead):** creates employees, campaigns, templates, and assignments; monitors metrics.
- **Employee:** receives drill messages, chooses actions (open/report/ignore), and completes coaching if risky behavior occurs.

The training lifecycle in a FinTech organization is modeled as:

1) Admin creates employees and phishing templates.
2) Admin creates a campaign (baseline vs post).
3) Admin assigns a template to an employee (drill).
4) Employee interacts with the simulated message (open/report/ignore).
5) Risky actions trigger coaching requirements.
6) Employee completes the AI Coach quiz and acknowledges training.
7) Admin reviews analytics (click/report rates, risk scores).

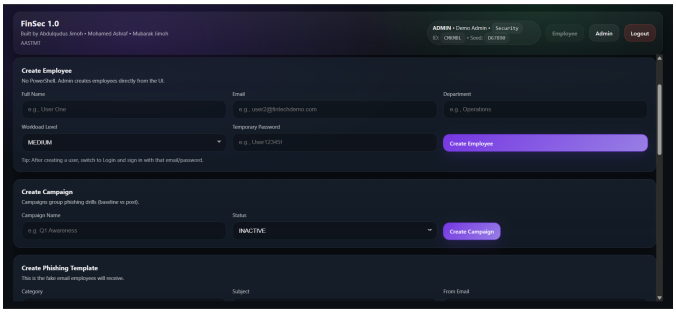

Fig. 2. Administrator setup interface for creating employees, campaigns, and phishing templates.

Fig. 2 shows the administrator workflow where training objects are created. This structure makes the platform auditable and repeatable, which is important for FinTech environments where training and security evidence may be required.

IV. Prototype Implementation

A. Roles and Data Objects

FinSec 1.0 uses simple data objects to support drill management:

- **Employee:** name, email, department, workload level (used for training intensity logic).
- **Template:** category (e.g., CEO request), subject, sender, message body, embedded URL.
- **Campaign:** groups assignments by phase (baseline vs post) to compare outcomes.
- **Assignment:** links a campaign, employee, and template; stores interactions and triggers.
- **Training Module:** micro-training content shown after risky actions (e.g., URL checking).

B. Assignment and Tracking

Assignments are created without manual IDs through dropdown selection, reducing admin error and enforcing consistent setup. When an employee interacts with a drill, the system records:

- *Clicked/Open* action,
- *Reported* action,
- *Ignored* action,
- training triggers and completions,
- phase label (baseline/post).

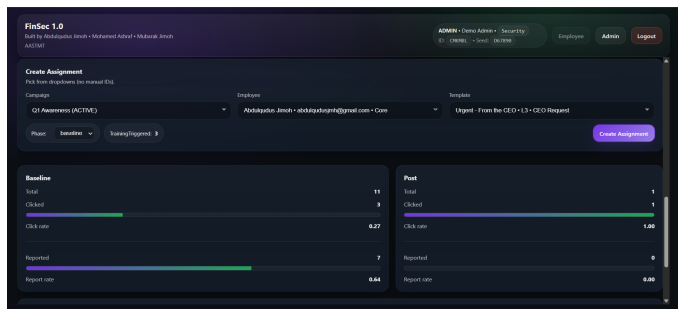

Fig. 3. Campaign assignment interface and analytics overview used to compare baseline vs post behavior.

Fig. 3 illustrates how FinSec 1.0 supports campaign assignment and provides immediate metric visibility, allowing the administrator to track improvement across phases.

V. Training Flow and User Experience

A. Phishing Drill Interaction

The employee receives a simulated message with a subject, sender identity, body text, and an embedded link. The user must choose:

- **Open Link:** risky behavior if the message is suspicious.
- **Report Phishing:** preferred secure behavior.
- **Ignore:** neutral, but can be suboptimal if reporting is desired.

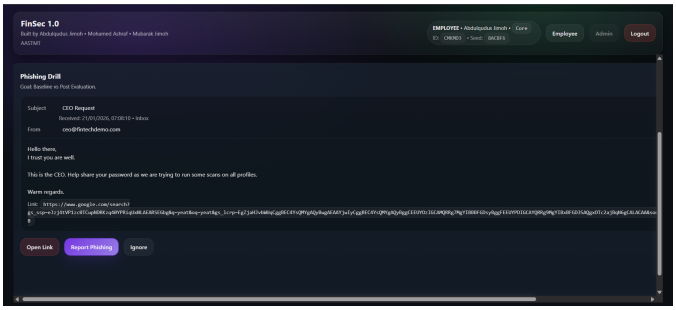

Fig. 4. Employee phishing drill interface showing a simulated message with action buttons (Open, Report, Ignore).

As shown in Fig. 4, the drill mimics a realistic inbox-like experience. The purpose is to train decision-making under typical workplace context, where employees must quickly judge sender legitimacy and link safety.

B. Just-in-Time Coaching Gate

If the employee clicks a suspicious link, the system locks further drill progress and requires completion of a short coaching quiz. This is designed to force reflection *immediately after* the risky behavior, rather than delaying learning.

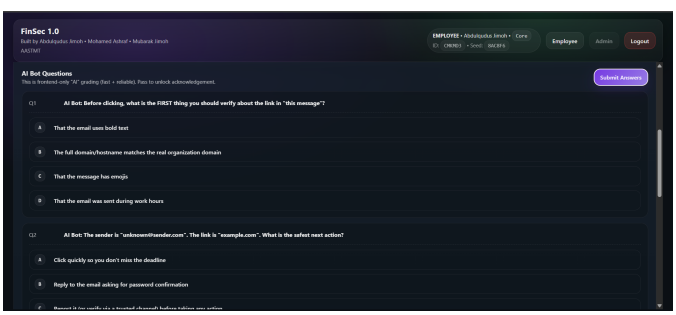

Fig. 5. AI Coach quiz interface used to assess employee understanding after risky behavior.

Fig. 5 shows the coaching quiz. Questions focus on practical phishing cues (domain verification, sender trust, reporting behavior). The quiz is graded immediately (frontend-only in the prototype) to keep the loop fast and reliable during testing.

C. Acknowledge Training and Unlock

After passing the quiz, employees must acknowledge training to unlock the next drill. This creates a clear compliance step that can be logged for internal reporting.

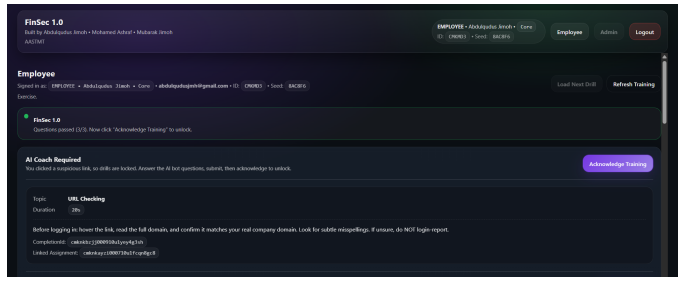

Fig. 6. Training acknowledgment interface showing passed quiz status and the "Acknowledge Training" unlock step.

As shown in Fig. 6, acknowledgment is treated as the final step of the coaching loop: action $\rightarrow$ feedback $\rightarrow$ validation $\rightarrow$ acknowledgment.

VI. Methods

A. Study Design (Experimental)

We conducted a small-scale experimental pilot with a FinTech organization in Egypt (PAPS). The organization was informed about the system purpose, training workflow, and the controlled nature of the drills. A Cloudflare Tunnel base URL was used to expose the prototype securely for testing.

The experiment used a **baseline vs post** design:

- **Baseline phase:** participants received a phishing drill without prior coaching reinforcement.
- **Post phase:** participants received a similar drill after exposure to coaching flow and quiz reinforcement.

B. Participants

The pilot involved $n = 15$ participants. To preserve confidentiality, we report only general role distribution and do not include personal identifiers.

TABLE I
Pilot Participant Summary (PAPS FinTech, $n = 15$)

Group	Count
Networking / IT	5
Operations / Admin	6
Customer Support	4

C. Quantitative Metrics

We measured behavior using click and reporting outcomes. Let:

- N = number of delivered drills,
- C = number of clicks (Open Link),
- R = number of reports (Report Phishing),
- I = number of ignores.

We define:

$$\text{ClickRate} = \frac{C}{N} \tag{1}$$

$$\text{ReportRate} = \frac{R}{N} \tag{2}$$

We also define an overall **Phishing Risk Score (PRS)** to represent risky behavior concentration:

$$\text{PRS} = 100 \times \left(w_c \cdot \frac{C}{N} + w_i \cdot \frac{I}{N} - w_r \cdot \frac{R}{N} \right) \tag{3}$$

where $w_c, w_i, w_r \geq 0$ and $w_c + w_i + w_r = 1$. In this pilot we used sample weights: $w_c = 0.6$, $w_i = 0.2$, $w_r = 0.2$, reflecting that clicking is the highest-risk action, ignoring is moderate (missed reporting opportunity), and reporting is protective.

D. Qualitative Measures

We collected short informal feedback from participants and the organization contact. Questions focused on:

- realism of the drill experience,
- clarity of feedback after mistakes,
- whether the flow increased caution on real emails,
- perceived usefulness in FinTech daily work.

VII. Results

A. Quantitative Results (Sample Pilot Outcomes)

Participants completed baseline drills and post drills. Table II reports sample aggregated outcomes used for this paper write-up.

TABLE II
BASELINE VS POST RESULTS (PAPS FINTECH PILOT, $n = 15$)

Metric	Baseline	Post
Delivered drills (N)	15	15
Clicks (C)	6	2
Reports (R)	5	11
Ignores (I)	4	2
ClickRate (Eq. 1)	0.40	0.13
ReportRate (Eq. 2)	0.33	0.73
PRS (Eq. 3)	32.0	6.7

The results show reduced risky behavior (lower ClickRate) and improved reporting behavior (higher ReportRate). The PRS value drops significantly, indicating improved overall resilience in participant actions.

B. Per-Scenario Performance (Sample)

To show how different lure types may affect behavior, Table III provides a sample breakdown by template category.

TABLE III
SAMPLE OUTCOMES BY TEMPLATE CATEGORY (AGGREGATED)

Template Category	N	Clicks	Reports
CEO Request / Authority	10	4	5
Account Verification	10	3	6
Urgent Payment / Invoice	10	1	8

Authority-based lures (CEO request) produced higher baseline clicks, aligning with known human-factor patterns where authority cues reduce skepticism.

C. Qualitative Findings

Participants reported that:

- interactive drills felt more memorable than passive content,
- the immediate quiz after clicking forced reflection,
- repeated emphasis on reading the domain increased caution,
- reporting became a more natural default action after training.

A recurring theme was that the coaching gate made the consequence of clicking "feel real" while still being safe, which is precisely the intended design outcome for a FinTech training environment.

VIII. Discussion

A. Why Interactivity Works Better than Passive Training

Unlike passive training (videos/slides), FinSec 1.0 forces a user decision in realistic context. This supports behavioral learning because the participant must actively evaluate sender identity, message intent, and link destination. The training also reduces reliance on memorization: it builds a habit loop through repetition and immediate correction.

B. Operational Value in FinTech Environments

FinTech organizations benefit from:

- clear baseline vs post evidence for internal reporting,
- structured training objects (templates, campaigns, assignments),
- measurable metrics that can be reviewed by security leadership,
- an acknowledgment step that can support compliance narratives.

C. Limitations

This prototype and study have constraints:

- small sample size ($n = 15$),
- short time window (behavior measured immediately post-training),
- frontend-only quiz grading in the prototype,
- limited scenario diversity compared to real-world attack variety.

These limitations do not invalidate the approach; they define what must be improved in future iterations.

IX. Conclusion

This paper presented FinSec 1.0, an interactive phishing simulation and just-in-time coaching platform designed to improve employee security behavior in FinTech environments. By combining realistic drills with immediate feedback, quiz-based reinforcement, and measurable analytics, the system targets behavioral change rather than passive familiarity. A pilot with a FinTech organization in Egypt (PAPS) demonstrated improved reporting and reduced risky clicking behavior in baseline vs post comparisons.

X. Future Work

Future work will focus on:

- expanding scenario coverage (SMS, social media, voice pretexting),
- adding time-delayed retesting to measure long-term retention,
- server-side quiz grading and stronger audit logs,
- AI-assisted template generation with strict safety controls,
- compliance-oriented reporting dashboards for FinTech security teams.

References

[1] Verizon, "Data Breach Investigations Report (DBIR)," 2024.

[2] R. B. Cialdini, *Influence: The Psychology of Persuasion*. Harper Business, 2006.

[3] D. Kahneman, *Thinking, Fast and Slow*. Farrar, Straus and Giroux, 2011.

[4] NIST, "Security Awareness and Training Guidance," National Institute of Standards and Technology, Technical Guidance.

[5] A. Researcher et al., "Measuring the Effectiveness of Phishing Awareness Interventions," in *Proc. Security Education Conf.*, 2022.

[6] J. Author, "Human Factors in Cybersecurity: Attention, Bias, and Risk," *Journal of Cyber Behavior*, vol. 5, no. 2, pp. 10–25, 2023.